

CNIC-Based Health Card System

Investor Prototype — Scope & Design Document

Version	Prototype v1.0
Scope	Investor demo — production features deferred
Stack	Supabase · Flutter (Android + iOS) · React (Web Admin)
Roles	Patient · Doctor · Lab Worker · Receptionist · Admin
Auth	Phone + Password (OTP, NADRA, MFA deferred to production)

5 Roles	12 DB Tables	40 Requirements	30 Use Cases	2 Build Phases
---------	--------------	-----------------	--------------	----------------

■ This document covers only the prototype scope for investor demonstration. Production features (NADRA verification, OTP, QR health cards, FHIR integration, offline mode, Urdu/RTL, PDPB compliance infrastructure, telehealth video, digital signatures, and secure messaging) are deliberately excluded and will be addressed in the production design document.

Section 1: Executive Summary

The CNIC-Based Health Card System is a centralized digital health platform for Pakistan. Every citizen's medical history is linked to their CNIC number, enabling any approved clinic, hospital, or diagnostic lab to access a patient's complete health record with the patient's consent. This eliminates the problem of fragmented, paper-based records that are lost between visits and institutions.

The prototype demonstrates the core value proposition: one patient identity, one continuous health record, accessible to any verified doctor. The five user roles — Patient, Doctor, Lab Worker, Receptionist, and Admin — each have a purpose-built interface with strictly enforced permission boundaries.

The prototype uses a deliberately lean stack: Supabase handles authentication, database, and file storage in one managed service. Flutter powers all four mobile roles from a single codebase. A React web app serves administrators. This lets the team build and demo quickly while keeping the architecture production-ready.

Section 2: System Overview and Architecture

2.1 Prototype Stack

The entire prototype runs on three services:

- Supabase — auth (email/phone + password), PostgreSQL database with Row Level Security, and file storage for lab result PDFs. One managed platform replaces auth service, DB, and storage.
- Flutter 3.x — single mobile codebase for Patient, Doctor, Lab Worker, and Receptionist apps. Role-based navigation via GoRouter routes each role to their own screen set after login.
- React 18 + TypeScript — web admin portal for system administrators. No mobile requirement for admin.

2.2 System Components

Component	Technology	Purpose
Auth	Supabase Auth	Phone/email + password login. JWT tokens. Session management.
Database	Supabase (PostgreSQL 15)	All clinical and user data. Row Level Security enforces role permissions at DB level.
File Storage	Supabase Storage	Lab result PDFs. Encrypted at rest. Signed URLs for access.
Patient App	Flutter (Android + iOS)	Patient-facing mobile: timeline, appointments, labs, profile.
Doctor App	Flutter (Android + iOS)	Doctor-facing: patient search, encounter creation, prescriptions, lab orders.
Lab Worker App	Flutter (Android + iOS)	Lightweight: order queue, sample tracking, result upload.
Receptionist App	Flutter (Android + iOS)	Shared app with role routing: clinic schedule, patient check-in, booking.
Admin Portal	React 18 (web)	Doctor/lab approvals, user management, clinic setup, basic dashboard.
Push Notifications	Firebase Cloud Messaging	In-app alerts for appointments, lab results, doctor approvals.

2.3 Architecture Decisions for Prototype

- No separate FHIR server — clinical data is stored directly in Supabase PostgreSQL tables with FHIR-compatible field names. HAPI FHIR sync is a production concern.
- No Redis, no RabbitMQ, no Elasticsearch — Supabase's built-in Postgres full-text search handles patient/drug lookups at prototype scale. Background jobs use Supabase Edge Functions.
- No message encryption at application layer — messages are protected by Supabase Row Level Security and TLS in transit. AES-GCM at application layer and HSM key management are production features.
- No offline mode — prototype requires active internet. Offline SQLite cache is a production feature.

- Single Supabase project for prototype. Production will split into separate auth and clinical schemas with stricter RLS policies and a dedicated FHIR layer.

Section 3: User Profiles — Field Definitions

3.1 Base Profile (all users)

Table: profiles

Field	Type	Constraints	Description
id	UUID	PRIMARY KEY	Internal system ID
auth_user_id	UUID	UNIQUE, NOT NULL, FK	Links to Supabase auth.users
cnic	VARCHAR(13)	UNIQUE, NOT NULL	13-digit Pakistan CNIC (no dashes). Validated by format only in prototype.
full_name	VARCHAR(255)	NOT NULL	Full legal name
date_of_birth	DATE	NOT NULL	Date of birth
gender	VARCHAR(10)	CHECK ('male','female','other')	Gender
phone_primary	VARCHAR(15)	NOT NULL	Primary mobile number
email	VARCHAR(255)	NULLABLE, UNIQUE	Optional email
role	VARCHAR(20)	NOT NULL	patient doctor lab_worker receptionist admin
status	VARCHAR(20)	DEFAULT 'pending'	active pending suspended rejected
status_reason	TEXT	NULLABLE	Admin note on status change
created_at	TIMESTAMPTZ	DEFAULT now()	Registration timestamp
updated_at	TIMESTAMPTZ	DEFAULT now()	Last profile update

3.2 Patient Extended Profile

Table: patient_profiles

Field	Type	Constraints	Description
id	UUID	PK, FK profiles(id)	Same ID as base profile
blood_group	VARCHAR(5)	NULLABLE	A+, A-, B+, B-, AB+, AB-, O+, O-, unknown
height_cm	DECIMAL(5,2)	NULLABLE	Height in centimetres
weight_kg	DECIMAL(5,2)	NULLABLE	Weight in kilograms
address_street	TEXT	NULLABLE	Home address
address_city	VARCHAR(100)	NULLABLE	City
address_province	VARCHAR(50)	NULLABLE	Punjab, Sindh, KPK, Balochistan, etc.
emergency_contact_name	VARCHAR(255)	NULLABLE	Emergency contact full name
emergency_contact_phone	VARCHAR(15)	NULLABLE	Emergency contact phone
known_allergies	TEXT	NULLABLE	Free text summary (structured in allergies table)
chronic_conditions_summary	TEXT	NULLABLE	Denormalized display summary
created_at	TIMESTAMPTZ	DEFAULT now()	Profile creation
updated_at	TIMESTAMPTZ	DEFAULT now()	Last update

3.3 Doctor Extended Profile

Table: doctor_profiles

Field	Type	Constraints	Description
id	UUID	PK, FK profiles(id)	Same ID as base profile
pmdc_number	VARCHAR(50)	UNIQUE, NOT NULL	PMDC registration number (stored, not auto-verified in prototype)
specialization_primary	VARCHAR(100)	NOT NULL	Primary specialty e.g. Cardiology
specialization_secondary	VARCHAR(100)	NULLABLE	Optional second specialty
qualification_mbbs	BOOLEAN	DEFAULT false	Holds MBBS
qualification_md	BOOLEAN	DEFAULT false	Holds MD
qualification_fcps	BOOLEAN	DEFAULT false	Holds FCPS
qualification_other	TEXT	NULLABLE	Other qualifications free text
years_of_experience	SMALLINT	NULLABLE	Self-reported
consultation_fee_pkr	DECIMAL(10,2)	NULLABLE	Fee in PKR shown to patients
bio	TEXT	NULLABLE	Doctor's public biography
is_available	BOOLEAN	DEFAULT true	Toggle availability without deactivating
approved_at	TIMESTAMPZ	NULLABLE	When admin approved
approved_by	UUID	NULLABLE, FK profiles	Admin who approved
created_at	TIMESTAMPZ	DEFAULT now()	Profile creation
updated_at	TIMESTAMPZ	DEFAULT now()	Last update

3.4 Lab Worker Extended Profile

Table: lab_worker_profiles

Field	Type	Constraints	Description
id	UUID	PK, FK profiles(id)	Same ID as base profile
lab_id	UUID	NOT NULL, FK diagnostic_labs	Which lab this worker belongs to
employee_id	VARCHAR(50)	NULLABLE	Internal employee ID at the lab
position_title	VARCHAR(100)	NULLABLE	e.g. Senior Lab Technician
approved_at	TIMESTAMPZ	NULLABLE	When admin activated account
created_at	TIMESTAMPZ	DEFAULT now()	Profile creation

3.5 Receptionist Extended Profile

Table: receptionist_profiles

Field	Type	Constraints	Description
id	UUID	PK, FK profiles(id)	Same ID as base profile
clinic_id	UUID	NOT NULL, FK clinics	Scoped to one clinic
employee_id	VARCHAR(50)	NULLABLE	Internal employee ID
approved_at	TIMESTAMPZ	NULLABLE	When admin activated account
created_at	TIMESTAMPZ	DEFAULT now()	Profile creation

3.6 Admin Profile

Table: admin_profiles

Field	Type	Constraints	Description
id	UUID	PK, FK profiles(id)	Same ID as base profile
admin_level	VARCHAR(20)	CHECK ('super_admin','support_admin')	super_admin has all powers
can_approve_doctors	BOOLEAN	DEFAULT true	Approve or reject doctor applications
can_approve_labs	BOOLEAN	DEFAULT true	Approve diagnostic labs
can_suspend_accounts	BOOLEAN	DEFAULT true	Suspend any non-admin account
created_at	TIMESTAMPTZ	DEFAULT now()	Profile creation

3.7 Supporting Entities

Clinics

Table: clinics

Field	Type	Description
id	UUID	PRIMARY KEY
name	VARCHAR(255)	Clinic or hospital name
type	VARCHAR(50)	clinic hospital polyclinic teaching_hospital basic_health_unit
phone	VARCHAR(15)	Main contact number
address_street	TEXT	Street address
address_city	VARCHAR(100)	City
address_province	VARCHAR(50)	Province
status	VARCHAR(20)	active suspended closed
created_at	TIMESTAMPTZ	

Diagnostic Labs

Table: diagnostic_labs

Field	Type	Description
id	UUID	PRIMARY KEY
name	VARCHAR(255)	Lab name
license_number	VARCHAR(100)	Government lab license (stored, admin verifies manually in prototype)
phone	VARCHAR(15)	Contact number
address_city	VARCHAR(100)	City
address_province	VARCHAR(50)	Province
status	VARCHAR(20)	active pending suspended
created_at	TIMESTAMPTZ	

Section 4: Database Schema

4.1 Scheduling Layer

doctor_availability

Field	Type	Description
id	UUID	PRIMARY KEY
doctor_id	UUID	FK doctor_profiles(id)
clinic_id	UUID	FK clinics(id)
day_of_week	SMALLINT	0=Sunday through 6=Saturday
start_time	TIME	Slot start
end_time	TIME	Slot end
slot_duration_minutes	SMALLINT	DEFAULT 15 — length of each bookable appointment
is_active	BOOLEAN	Doctor can pause a slot without deleting it
created_at	TIMESTAMPTZ	

appointments

Field	Type	Description
id	UUID	PRIMARY KEY
patient_id	UUID	FK patient_profiles(id)
doctor_id	UUID	FK doctor_profiles(id)
clinic_id	UUID	FK clinics(id)
appointment_date	DATE	NOT NULL
appointment_time	TIME	NOT NULL
appointment_type	VARCHAR(20)	in_person follow_up emergency
status	VARCHAR(30)	pending confirmed checked_in completed cancelled_by_patient cancelled_by_doctor no_show
booked_by_role	VARCHAR(20)	patient receptionist doctor
booked_by_id	UUID	FK profiles(id)
notes_for_doctor	TEXT	Patient's reason for visit
cancellation_reason	TEXT	NULLABLE
encounter_id	UUID	NULLABLE — linked when doctor creates encounter
created_at	TIMESTAMPTZ	
updated_at	TIMESTAMPTZ	

4.2 Clinical Data Layer

encounters

Field	Type	Description
id	UUID	PRIMARY KEY
patient_id	UUID	FK patient_profiles(id)

Field	Type	Description
doctor_id	UUID	FK doctor_profiles(id)
appointment_id	UUID	NULLABLE — FK appointments(id)
clinic_id	UUID	NULLABLE — FK clinics(id)
encounter_type	VARCHAR(50)	outpatient inpatient emergency follow_up
encounter_date	DATE	NOT NULL
chief_complaint	TEXT	Patient's stated reason for visit
history_of_present_illness	TEXT	Doctor's narrative
physical_examination_notes	TEXT	Findings from exam
assessment	TEXT	Doctor's clinical assessment
plan	TEXT	Treatment plan narrative
follow_up_required	BOOLEAN	DEFAULT false
follow_up_date	DATE	NULLABLE
follow_up_notes	TEXT	NULLABLE
status	VARCHAR(20)	draft finalized
finalized_at	TIMESTAMPTZ	When doctor finalized the encounter
created_at	TIMESTAMPTZ	
updated_at	TIMESTAMPTZ	

conditions

Field	Type	Description
id	UUID	PRIMARY KEY
encounter_id	UUID	FK encounters(id)
patient_id	UUID	FK patient_profiles(id) — denormalized
doctor_id	UUID	FK doctor_profiles(id)
icd10_code	VARCHAR(10)	NULLABLE — ICD-10 diagnosis code
condition_display	VARCHAR(500)	NOT NULL — human-readable name (free text is fine for prototype)
severity	VARCHAR(20)	mild moderate severe unknown
clinical_status	VARCHAR(20)	active inactive resolved
onset_date	DATE	NULLABLE
is_chronic	BOOLEAN	DEFAULT false
notes	TEXT	NULLABLE
created_at	TIMESTAMPTZ	

medication_requests

Field	Type	Description
id	UUID	PRIMARY KEY
encounter_id	UUID	FK encounters(id)
patient_id	UUID	FK patient_profiles(id)
doctor_id	UUID	FK doctor_profiles(id)
medication_name	VARCHAR(255)	Generic name — NOT NULL

Field	Type	Description
medication_brand	VARCHAR(255)	NULLABLE — brand name if specified
dosage_value	DECIMAL(8,3)	Numeric dosage amount
dosage_unit	VARCHAR(20)	mg ml units etc.
route	VARCHAR(50)	oral intravenous topical inhaled etc.
frequency	VARCHAR(50)	e.g. twice_daily every_8_hours
duration_days	SMALLINT	NULLABLE — how many days
instructions	TEXT	Patient instructions e.g. take with food
status	VARCHAR(30)	active completed cancelled
start_date	DATE	NULLABLE
end_date	DATE	NULLABLE
created_at	TIMESTAMPTZ	

observations (Vitals)

Field	Type	Description
id	UUID	PRIMARY KEY
encounter_id	UUID	FK encounters(id)
patient_id	UUID	FK patient_profiles(id)
authored_by_id	UUID	FK profiles(id)
observation_display	VARCHAR(255)	e.g. Blood Pressure Systolic, Pulse Rate
value_quantity	DECIMAL(12,4)	Numeric result
value_unit	VARCHAR(50)	mmHg bpm celsius % etc.
reference_range_text	VARCHAR(255)	Normal range description
observation_date	DATE	NOT NULL
created_at	TIMESTAMPTZ	

allergies

Field	Type	Description
id	UUID	PRIMARY KEY
patient_id	UUID	FK patient_profiles(id)
recorded_by_id	UUID	FK profiles(id)
encounter_id	UUID	NULLABLE — FK encounters(id)
substance_name	VARCHAR(255)	Allergen name — NOT NULL
allergy_type	VARCHAR(20)	allergy intolerance unknown
category	VARCHAR(20)	food medication environment other
criticality	VARCHAR(20)	low high unable_to_assess
reaction_description	TEXT	What happens when exposed
clinical_status	VARCHAR(20)	active inactive resolved
created_at	TIMESTAMPTZ	

4.3 Lab Workflow Layer

lab_orders

Field	Type	Description
id	UUID	PRIMARY KEY
encounter_id	UUID	FK encounters(id)
patient_id	UUID	FK patient_profiles(id)
ordering_doctor_id	UUID	FK doctor_profiles(id)
lab_id	UUID	FK diagnostic_labs(id)
test_name	VARCHAR(255)	Human readable test name — NOT NULL
priority	VARCHAR(20)	routine urgent stat
clinical_indication	TEXT	Why this test was ordered
special_instructions	TEXT	e.g. fasting required
status	VARCHAR(30)	ordered sample_collected processing resulted reviewed released_to_patient cancelled
ordered_at	TIMESTAMPTZ	
sample_collected_at	TIMESTAMPTZ	NULLABLE
resulted_at	TIMESTAMPTZ	NULLABLE
reviewed_at	TIMESTAMPTZ	NULLABLE
released_to_patient_at	TIMESTAMPTZ	NULLABLE

lab_results

Field	Type	Description
id	UUID	PRIMARY KEY
lab_order_id	UUID	UNIQUE, FK lab_orders(id)
lab_id	UUID	FK diagnostic_labs(id)
uploaded_by	UUID	FK lab_worker_profiles(id)
patient_id	UUID	FK patient_profiles(id)
result_file_url	TEXT	Supabase Storage URL to result PDF
result_file_name	VARCHAR(255)	Original file name
structured_results	JSONB	Optional: [{"name": "Haemoglobin", "value": 14.2, "unit": "g/dL"}]
comments	TEXT	Lab's comments on the result
created_at	TIMESTAMPTZ	

4.4 Audit Log

Table: audit_logs — basic append-only log for prototype. No UPDATE or DELETE granted on this table.

Field	Type	Description
id	UUID	PRIMARY KEY
actor_id	UUID	NULLABLE — FK profiles(id), NULL for system actions
actor_role	VARCHAR(20)	Role at time of action
action	VARCHAR(50)	login logout create read update status_change
resource_type	VARCHAR(50)	Table or entity name
resource_id	UUID	NULLABLE — ID of affected record

Field	Type	Description
patient_id	UUID	NULLABLE — if action involves patient data
status	VARCHAR(20)	success failure
timestamp	TIMESTAMPTZ	NOT NULL, DEFAULT now()

4.5 Notifications

Table: notifications — simple push notification log.

Field	Type	Description
id	UUID	PRIMARY KEY
recipient_id	UUID	FK profiles(id)
type	VARCHAR(50)	appointment_confirmed appointment_cancelled lab_result_ready doctor_approved doctor_rejected
title	VARCHAR(100)	Generic notification title
body	TEXT	Generic body — no clinical details
is_read	BOOLEAN	DEFAULT false
resource_id	UUID	NULLABLE — deep-link target (appointment, lab order, etc.)
created_at	TIMESTAMPTZ	DEFAULT now()

Section 5: Functional Requirements — Prototype Scope

■ Requirements marked [DEFERRED] exist in the full production spec but are excluded from this prototype. All requirement IDs are prefixed P- to distinguish prototype scope.

5.1 Registration and Identity

ID	Requirement
P-FR-001	Any person with a valid 13-digit CNIC may register as a patient with phone number and password. No NADRA verification or OTP in prototype — CNIC format is checked only.
P-FR-002	Doctors submit PMDC number, CNIC, qualifications, and clinic affiliation during registration. Account is created in PENDING status.
P-FR-003	Doctor accounts may not log in until an admin approves them via the admin portal.
P-FR-004	Admin creates receptionist accounts scoped to a specific clinic, and lab worker accounts scoped to a specific lab.
P-FR-005	The same CNIC cannot be registered for two accounts of any role.
P-FR-006	An account is suspended for 30 minutes after 5 consecutive failed login attempts.

5.2 Patient Features

ID	Requirement
P-FR-007	A patient can view their complete health timeline in reverse chronological order, showing encounters, diagnoses, medications, and lab results.
P-FR-008	A patient can filter their timeline by date range and record type.
P-FR-009	A patient can view the full detail of any encounter on their timeline.
P-FR-010	A patient can view a consolidated list of all active prescriptions across all encounters.
P-FR-011	A patient can view lab results that have been released to them by a doctor.
P-FR-012	A patient can search for doctors by name or specialization and view their public profile.
P-FR-013	A patient can book an appointment by selecting an available slot from a doctor's calendar.
P-FR-014	A patient can cancel an appointment up to 2 hours before the scheduled time.
P-FR-015	A patient can view upcoming and past appointments.
P-FR-016	A patient receives a push notification when a lab result is released to them.
P-FR-017	A patient can view their allergy list.
P-FR-018	A patient can update their demographic information (contact details, address, emergency contact, blood group, height, weight).

5.3 Doctor Features

ID	Requirement
P-FR-019	A doctor can search for a patient by entering their CNIC number.
P-FR-020	A doctor can view a patient's full health timeline after locating them.
P-FR-021	A doctor can create a new encounter for a patient, entering chief complaint, history, examination notes, assessment, and plan.
P-FR-022	A doctor can add one or more diagnoses (free text with optional ICD-10 code) to an encounter.
P-FR-023	A doctor can prescribe medications within an encounter with drug name, dosage, route, frequency, and duration.
P-FR-024	A doctor can record vitals (blood pressure, pulse, temperature, oxygen saturation, weight) within an encounter.

ID	Requirement
P-FR-025	A doctor can create a lab order within an encounter, specifying test name, lab, and priority.
P-FR-026	A doctor can finalize an encounter, after which the record is locked from editing.
P-FR-027	A doctor can set a follow-up date and instructions at the end of an encounter.
P-FR-028	A doctor is notified when a lab result is uploaded for one of their orders.
P-FR-029	A doctor can review a lab result and release it to the patient.
P-FR-030	A doctor can manage their weekly availability calendar (add, pause, or remove slots).
P-FR-031	A doctor can view their appointment list by day, confirm pending requests, and mark patients as checked in or no-show.
P-FR-032	A doctor can record a patient's allergy and mark it as confirmed.
P-FR-033	A doctor can view all active medications across all of a patient's encounters in one consolidated view.
P-FR-034	A doctor receives a warning if they prescribe a medication the patient is allergic to.
P-FR-035	A doctor can update their public profile including bio, qualifications, and consultation fee.

5.4 Lab Worker Features

ID	Requirement
P-FR-036	A lab worker sees only lab orders addressed to their specific lab, sorted by priority (STAT, urgent, routine).
P-FR-037	A lab worker can mark an order as sample collected, processing, and then upload a result PDF.
P-FR-038	Uploading a result notifies the ordering doctor automatically.
P-FR-039	A lab worker cannot view any part of a patient's health record beyond the order details (patient name and test information only).

5.5 Receptionist Features

ID	Requirement
P-FR-040	A receptionist can view and manage the appointment schedule for all doctors at their clinic.
P-FR-041	A receptionist can book an appointment on behalf of a walk-in patient.
P-FR-042	A receptionist can cancel an appointment on behalf of a patient.
P-FR-043	A receptionist can mark a patient as checked in.
P-FR-044	A receptionist cannot view clinical records — only demographic and appointment data.

5.6 Admin Features

ID	Requirement
P-FR-045	An admin can view and process the queue of pending doctor registration applications.
P-FR-046	An admin can approve or reject a doctor application with a mandatory reason.
P-FR-047	An admin can approve or reject diagnostic lab registrations.
P-FR-048	An admin can suspend any non-admin account with a mandatory reason, and reactivate it.
P-FR-049	An admin can create and manage clinic records.
P-FR-050	A super admin can create other admin accounts.
P-FR-051	An admin is notified when a new doctor or lab application is submitted.
P-FR-052	An admin can view a basic dashboard: total patients, approved doctors, appointments today, pending lab orders.

5.7 System-Level Requirements

ID	Requirement
P-FR-053	The system prevents a doctor from being double-booked for the same time slot.
P-FR-054	A patient receives a push notification when an appointment is confirmed or cancelled.
P-FR-055	File uploads for lab results are limited to 25 MB per file.

Section 6: Non-Functional Requirements — Prototype Scope

6.1 Security

ID	Requirement
P-NFR-001	All data in transit is encrypted using TLS 1.3 minimum. Supabase enforces this by default.
P-NFR-002	All data at rest in Supabase is encrypted using AES-256 (Supabase default).
P-NFR-003	JWT access tokens expire after 60 minutes. Refresh tokens expire after 7 days.
P-NFR-004	All API endpoints require a valid JWT Bearer token. Only registration and login are public.
P-NFR-005	RBAC is enforced server-side via Supabase Row Level Security policies — client-supplied role claims are never trusted.
P-NFR-006	Rate limiting: 100 API calls per user per minute. 5 failed login attempts trigger a 30-minute logout.

6.2 Performance

ID	Requirement
P-NFR-007	The patient health timeline API returns the first page (20 items) in under 2 seconds.
P-NFR-008	Patient search by CNIC for the doctor app returns results in under 1 second.
P-NFR-009	Doctor's daily appointment list loads in under 1 second.
P-NFR-010	Lab order queue for a lab worker loads in under 1 second.

6.3 Availability

ID	Requirement
P-NFR-011	Supabase managed service provides automated daily backups. Prototype relies on Supabase SLA.
P-NFR-012	No formal RTO/RPO target for prototype. Production will define 4-hour RTO, 1-hour RPO.

6.4 Usability

ID	Requirement
P-NFR-013	Minimum font size in mobile apps is 14sp with OS-level font scaling support.
P-NFR-014	All interactive elements have a minimum touch target of 48x48dp.
P-NFR-015	Error messages describe what went wrong and what the user should do — never just an error code.
P-NFR-016	A new patient can complete registration in under 3 minutes.

Section 7: Core Use Cases

7.1 Patient Use Cases

UC-P001: Register as a new patient

Actor	Unregistered person with a Pakistani CNIC and phone number
Precondition	None
Step 1	Open app and select Register as Patient
Step 2	Enter 13-digit CNIC, full name, date of birth, gender, and phone number
Step 3	Set a password and confirm
Step 4	Accept terms and conditions
Step 5	Land on the patient home screen with health timeline (initially empty)
Outcome	Patient profile created with status active. Audit log entry created.

UC-P002: View health timeline

Actor	Logged-in patient
Precondition	None
Step 1	Navigate to Timeline tab
Step 2	See all encounters in reverse chronological order — date, doctor name, clinic, primary diagnosis
Step 3	Tap any encounter to view full details: chief complaint, diagnoses, medications, vitals, follow-up
Outcome	Read event logged in audit_logs.

UC-P003: Book an appointment

Actor	Logged-in patient
Precondition	None
Step 1	Search for a doctor by name or specialization
Step 2	View doctor's public profile: qualifications, fee, bio, clinic affiliation
Step 3	Tap Book Appointment, select in-person or follow-up
Step 4	Browse available dates and time slots
Step 5	Select a slot, add reason for visit note, confirm
Outcome	Appointment created with status pending. Doctor receives push notification.

UC-P004: View lab results

Actor	Logged-in patient
Precondition	Lab result has been released by the ordering doctor
Step 1	Navigate to Labs tab
Step 2	See list of lab orders — those released show a result badge
Step 3	Tap a result to view structured values and download the PDF
Outcome	Read event logged.

UC-P005: View active prescriptions

Actor	Logged-in patient
Precondition	None
Step 1	Navigate to Medications tab

Step 2	See all currently active medication_requests across all encounters
Step 3	Each shows drug name, dosage, frequency, end date

7.2 Doctor Use Cases

UC-D001: Register as a doctor

Actor	Doctor with PMDC number and clinic affiliation
Precondition	None
Step 1	Select Register as Doctor in app
Step 2	Enter CNIC, full name, phone, date of birth
Step 3	Enter PMDC number and select primary specialization
Step 4	Enter qualifications and select clinic affiliation from list
Step 5	Set password and submit
Outcome	Account created in PENDING status. Admin receives push notification of new application.

UC-D002: Search patient by CNIC and open record

Actor	Logged-in approved doctor
Precondition	None
Step 1	Tap Search Patient on home screen
Step 2	Enter patient CNIC manually
Step 3	System finds patient and displays summary: name, blood group, known allergies, active conditions
Step 4	Navigate tabs: Timeline, Medications, Labs, Allergies
Outcome	READ audit log entry created for this doctor accessing this patient.

UC-D003: Create an encounter and prescribe

Actor	Logged-in doctor with a patient record open
Precondition	None
Step 1	Tap New Encounter
Step 2	Link to today's appointment if applicable
Step 3	Enter chief complaint, history of present illness, examination notes, assessment, plan
Step 4	Add diagnoses — search ICD-10 codes by keyword or type free text
Step 5	Add medications — enter drug name, dosage, route, frequency, duration
Step 6	System shows warning if drug matches a known allergy
Step 7	Record vitals in the structured vitals form
Step 8	Set follow-up date if needed, then tap Finalize Encounter
Outcome	Encounter status set to finalized. Encounter becomes read-only. Patient's timeline updated.

UC-D004: Review and release a lab result

Actor	Logged-in doctor
Precondition	Lab worker has uploaded a result
Step 1	Receive push notification that result is uploaded
Step 2	Open lab result from notification or Labs tab
Step 3	Review the PDF and any structured values entered by lab
Step 4	Tap Mark as Reviewed, then Release to Patient
Outcome	Patient receives push notification that result is available.

UC-D005: Manage availability calendar	
Actor	Logged-in doctor
Precondition	None
Step 1	Go to Schedule tab
Step 2	Tap Add Availability, select clinic, choose day of week
Step 3	Set start time, end time, and slot duration in minutes
Step 4	Save — slots are now visible to patients when booking
Outcome	doctor_availability records created. Patients can book those time slots.

7.3 Lab Worker Use Cases

UC-L001: Process a lab order	
Actor	Logged-in lab worker
Precondition	A doctor has created a lab order for this lab
Step 1	Home screen shows order queue for their lab — STAT first, then urgent, then routine
Step 2	Tap an order to view: order number, test name, patient first name only, clinical indication, special instructions
Step 3	Tap Mark Sample Collected — timestamp recorded
Step 4	Tap Mark Processing when test begins
Step 5	Upload result PDF from device, optionally enter structured values
Step 6	Tap Submit Result
Outcome	lab_results record created. Doctor receives push notification. Ordering doctor can now review and release.

UC-L002: Data access boundaries	
Actor	Logged-in lab worker
Precondition	None
Step 1	Lab worker can only see orders belonging to their lab
Step 2	Patient view shows first name and last initial only — no CNIC, no full address, no clinical history
Step 3	Lab worker has no access to encounters, prescriptions, or any other patient data

7.4 Receptionist Use Cases

UC-R001: Book appointment for walk-in patient	
Actor	Logged-in receptionist
Precondition	None
Step 1	Tap New Appointment on clinic dashboard
Step 2	Search existing patient by CNIC, or register a new patient on their behalf
Step 3	Select doctor and view available slots for today or a future date
Step 4	Select slot, add reason, confirm — booked_by_role is set to receptionist
Outcome	Appointment created. Patient and doctor notified via push.

UC-R002: Check in a patient	
Actor	Logged-in receptionist
Precondition	Patient has arrived for their appointment
Step 1	View today's clinic schedule on dashboard
Step 2	Find patient's appointment

Step 3	Tap Check In
Outcome	appointment.status set to checked_in. checked_in_at timestamp recorded.

UC-R003: View clinic schedule

Actor	Logged-in receptionist
Precondition	None
Step 1	Home screen shows today's full appointment list for all doctors at their clinic
Step 2	Each row shows time, doctor name, patient name, appointment type, status
Step 3	Receptionist can filter by doctor or appointment status

7.5 Admin Use Cases

UC-A001: Approve a doctor application

Actor	Admin
Precondition	Doctor has submitted registration
Step 1	Log in to React admin portal
Step 2	Go to Approvals, open pending doctor application
Step 3	Review submitted details: CNIC, PMDC number, qualifications, clinic affiliation
Step 4	Optionally verify PMDC number externally
Step 5	Click Approve (or Reject with mandatory reason)
Outcome	Doctor account status set to active. Doctor receives push notification.

UC-A002: Suspend and reactivate an account

Actor	Admin
Precondition	None
Step 1	Search user by CNIC or name in admin portal
Step 2	Open profile, click Suspend, enter mandatory reason
Step 3	To reactivate: find suspended account, click Reactivate, enter note
Outcome	Account status updated. Any active sessions invalidated on suspend. Audit log entry created.

UC-A003: Set up a clinic and staff

Actor	Admin
Precondition	None
Step 1	Create a clinic record in Clinics section with name, type, city, phone
Step 2	Create receptionist account: enter CNIC, name, phone, assign to clinic
Step 3	Receptionist can now log in and manage that clinic's schedule

Section 8: Entity Relationship Summary

8.1 Entities and Primary Keys

Entity	PK	Key Relationships
profiles	id UUID	auth_user_id -> Supabase auth.users
patient_profiles	id UUID	id -> profiles.id (1:1)
doctor_profiles	id UUID	id -> profiles.id (1:1)
lab_worker_profiles	id UUID	id -> profiles.id (1:1), lab_id -> diagnostic_labs
receptionist_profiles	id UUID	id -> profiles.id (1:1), clinic_id -> clinics
admin_profiles	id UUID	id -> profiles.id (1:1)
clinics	id UUID	Referenced by appointments, doctor_availability, receptionist_profiles
diagnostic_labs	id UUID	Referenced by lab_orders, lab_worker_profiles
doctor_availability	id UUID	doctor_id -> doctor_profiles, clinic_id -> clinics
appointments	id UUID	patient_id, doctor_id, clinic_id, encounter_id (nullable)
encounters	id UUID	patient_id, doctor_id, appointment_id (nullable), clinic_id
conditions	id UUID	encounter_id, patient_id, doctor_id
medication_requests	id UUID	encounter_id, patient_id, doctor_id
observations	id UUID	encounter_id, patient_id
allergies	id UUID	patient_id, encounter_id (nullable)
lab_orders	id UUID	encounter_id, patient_id, ordering_doctor_id, lab_id
lab_results	id UUID	lab_order_id (1:1), lab_id, uploaded_by, patient_id
audit_logs	id UUID	actor_id -> profiles, resource_id (generic)
notifications	id UUID	recipient_id -> profiles

8.2 Key Cardinalities

Relationship	Cardinality	Note
profiles -> patient_profiles	1:1	Every patient profile extends the base profile
profiles -> doctor_profiles	1:1	Every doctor profile extends the base profile
doctor_profiles -> appointments	1:many	A doctor has many appointments
patient_profiles -> appointments	1:many	A patient has many appointments
appointments -> encounters	1:0..1	An appointment may produce one encounter
encounters -> conditions	1:many	An encounter may have multiple diagnoses
encounters -> medication_requests	1:many	An encounter may have multiple prescriptions
encounters -> observations	1:many	An encounter may have multiple vitals
encounters -> lab_orders	1:many	An encounter may have multiple lab orders
lab_orders -> lab_results	1:1	One result per order
patient_profiles -> allergies	1:many	A patient may have many recorded allergies

Relationship	Cardinality	Note
diagnostic_labs -> lab_orders	1:many	A lab receives many orders
clinics -> appointments	1:many	A clinic hosts many appointments

Section 9: Sequence Diagram Descriptions

9.1 Patient Registration

Step	Actor	Action
1	Patient (App)	Submits CNIC, name, DOB, gender, phone, password
2	API	Validates CNIC format (13 digits). Checks CNIC uniqueness across all roles
3	Supabase Auth	Creates auth.users entry, returns user ID
4	API	Creates profiles row (role=patient, status=active)
5	API	Creates patient_profiles row with default values
6	Audit Service	Logs registration event
7	API -> App	Returns success + JWT access token
8	App	Navigates patient to home screen (empty timeline)

9.2 Doctor Login

Step	Actor	Action
1	Doctor (App)	Submits CNIC and password
2	Supabase Auth	Validates credentials, checks account status = active
3	API	Checks profiles.status — rejects if pending, suspended, or rejected with clear error
4	Audit Service	Logs login success or failure
5	API -> App	Returns JWT + role metadata
6	App	Routes doctor to doctor home screen (today's appointments)

9.3 Doctor Creates Encounter

Step	Actor	Action
1	Doctor	Opens patient record (found by CNIC search)
2	API	Returns patient profile, timeline summary, allergies
3	Doctor	Taps New Encounter, selects linked appointment if applicable
4	API	Creates encounter with status=draft
5	Doctor	Fills chief complaint, history, examination, assessment, plan
6	Doctor	Adds diagnoses (ICD-10 search or free text)
7	Doctor	Adds medications — API checks each drug against patient allergy list and returns warning if match found
8	Doctor	Records vitals in structured form
9	Doctor	Taps Finalize Encounter
10	API	Sets encounter.status=finalized, encounter.finalized_at=now()
11	Audit	Logs encounter finalization
12	FCM	Pushes generic notification to patient: new record added to timeline

9.4 Lab Result Upload and Release

Step	Actor	Action
1	Lab Worker	Opens order queue, taps pending order
2	Lab Worker	Marks sample collected, then marks processing
3	Lab Worker	Uploads result PDF from device
4	Supabase Storage	Stores file with server-side AES-256 encryption, returns URL
5	API	Creates lab_results record with file URL. Updates lab_order.status=resulted
6	FCM	Notifies ordering doctor: result uploaded for review
7	Doctor	Opens result, reviews PDF and structured values, taps Release to Patient
8	API	Sets lab_order.status=released_to_patient, released_to_patient_at=now()
9	FCM	Notifies patient: new lab result available

Section 10: State Machines

10.1 Appointment Status

From State	Event	To State
(none)	Patient or receptionist books	pending
pending	Doctor confirms	confirmed
pending	Doctor declines	cancelled_by_doctor
confirmed	Patient cancels (>2 hrs before)	cancelled_by_patient
confirmed	Doctor cancels	cancelled_by_doctor
confirmed	Patient arrives, receptionist/doctor checks in	checked_in
checked_in	Doctor begins consultation	in_progress
in_progress	Doctor finalizes encounter	completed
confirmed	Appointment time passes with no show	no_show

10.2 Encounter Status

From State	Event	To State
(none)	Doctor creates encounter	draft
draft	Doctor adds content and finalizes	finalized

■ *In the prototype, encounters cannot be amended after finalization. Amendment workflow is a production feature.*

10.3 Lab Order Status

From State	Event	To State
(none)	Doctor creates order in encounter	ordered
ordered	Doctor cancels before sample taken	cancelled
ordered	Lab worker marks sample collected	sample_collected
sample_collected	Lab worker marks processing	processing
processing	Lab worker uploads result	resulted
resulted	Doctor reviews result	reviewed
reviewed	Doctor releases to patient	released_to_patient

10.4 Doctor Account Status

From State	Event	To State
(none)	Doctor submits registration	pending
pending	Admin approves	active
pending	Admin rejects	rejected
active	Admin suspends	suspended
suspended	Admin reactivates	active

10.5 Medication Request Status

From State	Event	To State
draft	Encounter finalized	active
active	end_date passes	completed
active	Doctor cancels prescription	cancelled
active	Doctor puts on hold	on_hold
on_hold	Doctor reactivates	active

Section 11: API Surface Overview

11.1 Authentication Endpoints

Method	Endpoint	Description
POST	/auth/register	Register new patient (CNIC, name, phone, password)
POST	/auth/register/doctor	Register new doctor (CNIC, PMDC, qualifications, clinic)
POST	/auth/login	Login with CNIC + password -> returns JWT
POST	/auth/logout	Invalidate session
POST	/auth/refresh	Refresh JWT access token

11.2 Patient Endpoints

Method	Endpoint	Description
GET	/me	Get own profile
PATCH	/me	Update own profile (demographics, emergency contact)
GET	/me/timeline	Paginated health timeline (encounters, conditions, meds, labs)
GET	/me/medications	All active prescriptions
GET	/me/labs	All lab orders and released results
GET	/me/allergies	All recorded allergies
GET	/me/appointments	Upcoming and past appointments
POST	/appointments	Book an appointment
PATCH	/appointments/:id/cancel	Cancel an appointment
GET	/doctors	Search doctors by name/specialization
GET	/doctors/:id	Doctor public profile
GET	/doctors/:id/availability	Available slots for booking

11.3 Doctor Endpoints

Method	Endpoint	Description
GET	/patients/search	Search patient by CNIC
GET	/patients/:id	Patient summary (requires audit log)
GET	/patients/:id/timeline	Patient full timeline
GET	/patients/:id/medications	Patient consolidated medication list
GET	/patients/:id/allergies	Patient allergy list
POST	/encounters	Create new draft encounter
PATCH	/encounters/:id	Update draft encounter fields
POST	/encounters/:id/finalize	Finalize encounter (locks it)
POST	/encounters/:id/conditions	Add diagnosis to encounter
POST	/encounters/:id/medications	Add prescription to encounter
POST	/encounters/:id/vitals	Record vitals observation

Method	Endpoint	Description
POST	/encounters/:id/lab-orders	Create lab order within encounter
GET	/doctor/appointments	Doctor's appointment list (filter by date)
PATCH	/appointments/:id/confirm	Confirm a pending appointment
PATCH	/appointments/:id/cancel	Cancel an appointment
PATCH	/appointments/:id/check-in	Mark patient as checked in
PATCH	/appointments/:id/no-show	Mark as no-show
GET	/doctor/lab-orders	All lab orders awaiting review
PATCH	/lab-orders/:id/review	Mark lab order as reviewed
PATCH	/lab-orders/:id/release	Release result to patient
GET	/doctor/availability	Doctor's own availability slots
POST	/doctor/availability	Add availability slot
DELETE	/doctor/availability/:id	Remove availability slot
POST	/patients/:id/allergies	Record allergy for patient

11.4 Lab Worker Endpoints

Method	Endpoint	Description
GET	/lab/orders	Order queue for this lab worker's lab (priority sorted)
GET	/lab/orders/:id	Order detail (limited patient info only)
PATCH	/lab/orders/:id/collect	Mark sample collected
PATCH	/lab/orders/:id/processing	Mark as processing
POST	/lab/orders/:id/result	Upload result PDF + optional structured values

11.5 Receptionist Endpoints

Method	Endpoint	Description
GET	/clinic/appointments	Today's schedule for all doctors at this clinic
POST	/appointments	Book appointment on behalf of patient
PATCH	/appointments/:id/cancel	Cancel appointment
PATCH	/appointments/:id/check-in	Mark patient as checked in
GET	/patients/search	Search patient by CNIC (name + appointment info only, no clinical)

11.6 Admin Endpoints

Method	Endpoint	Description
GET	/admin/applications/doctors	Pending doctor applications queue
GET	/admin/applications/doctors/:id	Doctor application detail
POST	/admin/applications/doctors/:id/approve	Approve doctor
POST	/admin/applications/doctors/:id/reject	Reject with reason
GET	/admin/applications/labs	Pending lab applications
POST	/admin/applications/labs/:id/approve	Approve lab
POST	/admin/applications/labs/:id/reject	Reject lab

Method	Endpoint	Description
GET	/admin/users	User list with filters
POST	/admin/users/:id/suspend	Suspend account with reason
POST	/admin/users/:id/reactivate	Reactivate account
POST	/admin/clinics	Create clinic record
PATCH	/admin/clinics/:id	Update clinic
POST	/admin/users/receptionist	Create receptionist account
POST	/admin/users/lab-worker	Create lab worker account
GET	/admin/dashboard	Aggregate stats: patients, doctors, today's appointments, pending orders

Section 12: Security Model

12.1 Authentication Flow

- Supabase Auth handles all authentication. Users log in with CNIC + password (mapped to email field for Supabase compatibility) or phone + password.
- Supabase issues a short-lived JWT (60 min) and a refresh token (7 days). All API calls include the Bearer token in the Authorization header.
- On login, the API reads the role from the profiles table and returns it to the client for navigation routing. The role is never trusted from the client for permission checks.
- Failed logins are counted in profiles.failed_login_attempts. After 5 failures, profiles.locked_until is set to now() + 30 minutes and login is rejected until then.

12.2 Authorization — Row Level Security

- Every Supabase table has RLS policies that enforce role-based access at the database level. The application layer is a second check — the database is the source of truth.
- Patients can only SELECT rows where patient_id = auth.uid() on their own data.
- Doctors can SELECT encounters, conditions, medications, labs only after an explicit patient lookup audit log entry exists (proving the doctor searched for this patient).
- Lab workers can SELECT only lab_orders and lab_results where lab_id matches their lab_worker_profiles.lab_id. No access to encounters, conditions, or medications.
- Receptionists can SELECT only appointments where clinic_id matches their receptionist_profiles.clinic_id. No clinical data access.
- Admins have broader SELECT rights but cannot UPDATE or DELETE from audit_logs, encounters (finalized), or profiles.cnic.

12.3 Data Protection

- All data in transit protected by TLS 1.3 (enforced by Supabase).
- All data at rest encrypted with AES-256 (Supabase default on managed Postgres and Storage).
- Lab result PDFs stored in Supabase Storage with signed URL access — only authenticated users with the correct role can generate a signed URL for a specific file.
- CNIC is stored as plain text in the prototype. Production will add bcrypt hashing with an HMAC-based lookup index.

Section 13: Role and Permission Matrix

Action	Patient	Doctor	Lab Worker	Receptionist	Admin
View own profile	Y	Y	Y	Y	Y
View own health timeline	Y	-	-	-	-
View any patient timeline	-	Y*	-	-	Y
Create/update encounter	-	Y	-	-	-
Finalize encounter	-	Y	-	-	-
Prescribe medication	-	Y	-	-	-
Record vitals	-	Y	-	-	-
Create lab order	-	Y	-	-	-
View lab order queue	-	-	Y+	-	-
Upload lab result	-	-	Y+	-	-
Review and release lab result	-	Y	-	-	-
Book appointment	Y	-	-	Y	-
Confirm/cancel appointment	Y^	Y	-	Y	-
View clinic schedule	-	Y	-	Y	Y
Approve/reject doctor application	-	-	-	-	Y
Suspend/reactivate accounts	-	-	-	-	Y
Create clinic/lab records	-	-	-	-	Y
Create receptionist/lab worker	-	-	-	-	Y
View audit logs	-	-	-	-	Y

- Y* Doctor can view any patient's timeline after performing a CNIC search (audit-logged).
- Y+ Lab worker sees only orders and results belonging to their assigned lab.
- Y^ Patient can only cancel — not confirm — their own appointments.

Section 14: Notification Types — Prototype

Prototype delivers push notifications via Firebase Cloud Messaging (FCM) only. SMS gateway is a production feature. Notification bodies never contain clinical details, patient names, diagnosis names, or appointment types — generic text only, with a deep link.

ID	Event	Recipient	Trigger
NT-001	appointment_confirmed	Patient	Doctor confirms a pending appointment
NT-002	appointment_cancelled	Patient	Doctor or receptionist cancels an appointment
NT-003	lab_result_uploaded	Doctor	Lab worker marks order as resulted
NT-004	lab_result_released	Patient	Doctor releases result to patient
NT-005	doctor_application_update	Doctor	Admin approves or rejects doctor registration

■ Appointment reminders (24h and 1h), medication renewal reminders, and refill request notifications are deferred to production. They require a background job scheduler which is not part of the prototype stack.

Section 15: Audit — Prototype Scope

The prototype logs the following events to the audit_logs table. The table is append-only: no UPDATE or DELETE permission is granted to any role including the app service account.

Event	Logged When
login_success	User successfully authenticates
login_failure	Failed login attempt (wrong password or locked account)
logout	User logs out
patient_record_viewed	Doctor or admin reads a patient's encounter, medication, or lab data
encounter_created	Doctor creates a new encounter
encounter_finalized	Doctor finalizes an encounter
lab_result_uploaded	Lab worker uploads a result
lab_result_released	Doctor releases result to patient
account_status_changed	Admin suspends, reactivates, approves, or rejects an account

Full PDPB compliance audit infrastructure, data retention policies, and breach notification automation are production concerns outside prototype scope.

Section 16: Implementation Phases

Phase 1 — Core Foundation (Weeks 1-3)

- Supabase project setup: create all tables, RLS policies, and audit trigger functions.
- Supabase Auth integration: phone/email + password registration and login for all roles.
- Base profile and role-extended profile creation on registration.
- Flutter app skeleton: GoRouter setup, login screen, role-based navigation to correct home screen.
- Patient home: empty timeline, profile view and edit.
- Doctor home: patient search by CNIC, patient summary view.
- Admin web portal skeleton: login, doctor application queue, approve/reject flow.
- FCM push notification integration for all platforms.

Phase 2 — Clinical Workflows and Demo Polish (Weeks 4-6)

- Encounter management: full creation, editing, diagnoses, medications (with allergy check), vitals, finalization.
- Patient timeline: all encounter types displayed in chronological view with detail tap-through.
- Appointment scheduling: doctor availability management, patient booking, confirmation flow, receptionist check-in.
- Lab workflow: lab worker order queue, sample tracking, PDF upload, doctor review and release to patient.
- Admin portal: clinic creation, lab approval, receptionist and lab worker account creation, basic dashboard.
- Notifications: all 5 notification types wired up and tested end-to-end.
- Allergy conflict warning on prescription.
- Consolidated medication view for doctor.
- Polish: loading states, error messages, empty state screens, app icons, onboarding flow.
- Demo data seed script: pre-load sample patients, doctors, encounters, and lab results for live demo.